Project & Portfolio VII: Cybersecurity | Full Sail University | July 2026

Academic coursework. The company, the two-site environment and all host data are fictional and part of the course scenario. All scanning was performed against isolated lab virtual machines.

This is an excerpt. The full report is 145 pages and the full ticket report is 141; included here are the research on controls for vulnerabilities that cannot be patched, the remediation plan for the firewall, server and end-of-life systems, two complete tickets with screenshot evidence, and the ticket report's conclusion.

Redacted for publication: IP addresses, hostnames and domain names, lab usernames, credentials, instructor names. Black boxes mark removed content.

WEEK 3 – 3.3 ASSIGNMENT

1. RESEARCH ON WHAT CONTROLS CAN BE PUT IN PLACE FOR NON-PATCHING VULNERABILITIES

Managing non-patching vulnerabilities, whether caused by vendor delay, end-of-life systems, or critical uptime constraints, requires relying on compensating controls to reduce risk until a permanent fix is available. Below are five operational scenarios detailing how to research the underlying risk and implement administrative and technical controls.

1. END-OF-LIFE (EOL) AND UNSUPPORTED LEGACY SYSTEMS
RESEARCH APPROACH

Researching unsupported software or operating systems begins by identifying active threat vectors using CISA's Known Exploited Vulnerabilities (KEV) catalog, the National Vulnerability Database (NVD), and threat intelligence feeds. I evaluate exploitability using the Exploit Prediction Scoring System (EPSS) and analyze MITRE ATT&CK techniques to map potential lateral movement paths from the legacy asset into the broader network.

- **Risk Acceptance Policy:** Formalize a time-bound risk acceptance document signed by executive leadership, outlining an explicit migration roadmap and replacement deadline.
- **SOPs & Auditing:** Establish strict operational procedures requiring quarterly risk reviews and specialized security awareness training for operators handling legacy nodes.
- **Network Micro-segmentation:** Isolate legacy assets onto dedicated, restricted VLANs behind Next-Generation Firewalls (NGFWs) with zero outbound internet access.
- **System Hardening:** Deploy host-based Application Whitelisting (WDAC/AppLocker) to block unauthorized execution, revoke local administrative rights, and install behavior-based Endpoint Detection and Response (EDR) agents.

2. ZERO-DAY VULNERABILITIES IN ACTIVE PRODUCTION SOFTWARE
RESEARCH APPROACH

When researching zero-day vulnerabilities prior to a vendor patch release, I examine vendor advisories, US-CERT alerts, and dynamic Proof-of-Concept (PoC) exploit code on repositories like GitHub or Exploit-DB. The goal is to dissect the payload mechanics—such as specific HTTP parameters, headers, or API calls—to determine exactly how the attack triggers remote code execution or privilege escalation.

- **Emergency Change Management:** Execute an Incident Response Playbook to create a time-bound exception entry in the enterprise Risk Register.
- **Operational Directives:** Publish interim guidance for IT helpdesks and system administrators specifying authorized operational workarounds and temporary feature restrictions.

- **Virtual Patching:** Deploy targeted web application firewall (WAF) or network Intrusion Prevention System (IPS) rules to inspect incoming traffic and drop malicious signatures at the perimeter.
- **Attack Surface Reduction:** Disable vulnerable background services, require VPN or multi-factor authentication (MFA) for access, and create custom SIEM detection rules to flag exploit attempts.

3. Mission-Critical Industrial / OT Devices with Downtime Restrictions
Research Approach

For Operational Technology (OT), SCADA, or medical devices where applying a patch risks unacceptable operational downtime, research focuses on ICS-CERT advisories and vendor-specific defense bulletins. I evaluate protocol-level vulnerabilities (e.g., Modbus, DNP3, DICOM) to verify whether exploitation requires physical proximity, specific network packets, or local console interaction.

- **SLA & Deferred Patch Policies:** Require formal business-owner authorization to defer patching until scheduled maintenance windows, documenting all business justifications.
- **Physical Security Controls:** Enforce strict physical access controls around OT consoles and mandate air-gapped scanning stations for all removable media (USB drives).
- **Purdue Model Segmentation:** Architect strict zone isolation separating industrial control networks from corporate IT using jump hosts and unidirectional data diodes.
- **Passive Anomaly Monitoring:** Bind device communication exclusively to allowed MAC/IP addresses and deploy passive network monitoring tools to detect unexpected command sequences without impacting system availability.

4. In-House Legacy Software with Missing Source Code
Research Approach

When addressing proprietary, legacy applications where source code has been lost or original developers are unavailable, research relies on black-box security testing. I perform Dynamic Application Security Testing (DAST) and interactive proxy analysis (e.g., OWASP ZAP, Burp Suite) to map vulnerable input fields, API endpoints, and database calls without altering executable binaries.

- **Deprecation Strategy:** Mandate an architectural lifecycle policy that sets a firm deadline for refactoring or replacing the unmaintainable application.
- **Data Handling Policies:** Restrict the types of sensitive data processed by the application to limit organizational liability under relevant regulatory frameworks.
- **Reverse Proxy / API Gateway:** Position the application behind an inspecting proxy configured with input validation, parameter sanitization, and rate-limiting controls.
- **Host & Database Hardening:** Enable OS-level runtime protections (DEP, ASLR), enforce least-privilege database user accounts, and containerize the application environment to restrict host system access.

5. Vulnerable Edge Appliances and Embedded Firmware Research Approach

When perimeter security hardware (e.g., VPN gateways, firewalls, NAS appliances) harbors uncatchable firmware flaws, research centers on monitoring vendor security centers, dark web exploit markets, and CISA advisories. Research targets identifying whether management interfaces, exposed administrative ports, or specific network protocols are vulnerable to initial access vectors.

- **Vendor Risk Management:** Enforce vendor SLAs requiring timely security updates, establishing contractual clauses for hardware replacement if a vendor abandons security support.
- **Failover Response Plans:** Maintain updated Incident Response Playbooks detailing manual failover procedures to secondary, clean hardware if compromise is suspected.
- **Interface Isolation:** Remove management interfaces entirely from public internet exposure, restricting administrative access to dedicated, multi-factor authenticated out-of-band networks.
- **Edge Defense & Logging:** Apply Geo-IP filtering and IP whitelisting at perimeter gateways, deploy IPS signature blocks, and stream real-time device logs to a central SIEM configured with automated alerts for anomalous login attempts.

2. LISTING OF ALL REMEDIATION, THE CRITICAL & HIGH VULNERABILITIES PER VM.

The following remediation plan pairs every Critical and High vulnerability documented in the Week 3 (3.3) scans with a corrective action. Because most virtual machines returned dozens to hundreds of findings that resolve to the same fix (for example, a single missing monthly cumulative update or an out-of-date library), remediations are grouped by the affected software component rather than repeated per plugin ID. Applying the grouped remediation clears every finding tied to that component. Machines are patched during scheduled maintenance windows, rebooted, and re-scanned to confirm closure.

End-of-life systems. The ORLws1, SFOserver, and SFOws1 hosts run operating systems that are past vendor end-of-support. No vendor patch will remediate their findings; the only durable fix is migrating to a currently supported operating system and re-licensing. Compensating controls (isolation, hardening, disabling legacy protocols) are listed to reduce risk until migration is complete, consistent with the EOL control strategy established earlier in this assignment.

5555 [redacted]

· LAN [redacted] · SFO [redacted] · WAN [redacted]

Root cause: Plugin 33850 (Unsupported Unix OS, CVSS 10.0) shows the firewall's FreeBSD base is out of date, which is why so many bundled packages are flagged. Upgrading the firewall to the current supported release rebases the entire package set and resolves most findings in a single action. Back up the running config and snapshot the VM before upgrading.

Affected Component / Finding	Remediation
Firewall base OS (33850)	Upgrade pfSense/OPNsense to the current supported release, which ships a supported FreeBSD base and updated packages. Perform in a maintenance window after a full config backup; reboot and re-scan.
OpenSSL (305290, 320568, 206514, 198058, 183822)	Update OpenSSL to the patched branch via the platform upgrade; restart dependent services (VPN, web GUI, IPsec).
OpenVPN (310335, 185811, 324994, 200822, 233819, 214337)	Upgrade OpenVPN to the fixed 2.6.x release; verify tls-crypt-v2 handling and enforce username/password [redacted]
strongSwan / IPsec (320012, 271783, 186241)	Upgrade strongSwan to the patched version. Disable the charon-tkm and eap-mschapv2 plugins if IPsec/EAP-MSCHAPv2 is not in use.
Unbound DNS resolver (320011, 242336, 271377)	Upgrade Unbound; disable EDNS Client Subnet (ECS) if not required and restrict recursion to internal clients to prevent cache-poisoning.
Suricata IDS/IPS (233787, 190936)	Update the Suricata engine and refresh rule sets.
PHP web GUI (232759, 193406, 208145, 241330)	Update the bundled PHP packages; restrict management-interface access to the LAN/out-of-band network only.
SQLite (272021, 242649, 243313)	Update the SQLite library (delivered with the base upgrade).
curl (182913, 181521)	Update curl to the fixed release.
OpenSSH (207372, 201214)	Update OpenSSH; limit SSH to an out-of-band management network and enforce key-based auth.
Supporting libraries (Jinja2, krb5, sudo, dnsmasq, expat, libxml2, ldns, nghttp2, cpython, py-cryptography, pkcs11-	All resolved by the platform/base-OS upgrade, which rebases these packages. Confirm closure with a post-upgrade re-scan.

Affected Component / Finding	Remediation
helper, squid, DNSSEC/KeyTrap)	
Compensating controls (until upgrade)	Remove all administrative access from the WAN interface [redacted] require MFA for management, apply geo-IP / IP allow-listing at the edge, and stream firewall logs to the SIEM.

5556 [redacted]

Affected Component / Finding	Remediation
Missing Windows cumulative updates (KB5029247 … KB5094123 — ~40 monthly rollups)	Deploy all outstanding Windows Server 2019 monthly cumulative security updates through the latest available via WSUS/SCCM/Intune. A current cumulative update supersedes every older missing KB. Reboot and re-scan to confirm.
.NET Framework security updates (185887, 187901, 271264, 179664, 214274, 177393, 181375, 208757, 193217, 202304, 314930)	Apply the current Microsoft .NET Framework security rollups for the installed .NET version.
WinVerifyTrust signature validation (166555)	Set the EnableCertPaddingCheck registry value (per CVE-2013-3900 guidance) to enforce Authenticode signature validation.
curl 7.84–8.2.1 header DoS (181409, CVE-2023-38039)	Update the standalone/bundled curl binary to 8.3.0 or later.
Process control	Establish a monthly patch cadence (Patch Tuesday +7 days) so cumulative updates are applied on an ongoing basis.

5562 [redacted]

END OF LIFE — Windows 10 reached end of support on October 14, 2025. Without an Extended Security Updates (ESU) subscription it receives no further patches.

Affected Component / Finding	Remediation
Operating system (primary remediation)	Migrate the workstation to Windows 11 (or another supported OS) with valid licensing. If the hardware is not Windows 11-eligible, purchase Windows 10 ESU as a temporary bridge or replace the device; then decommission the Windows 10 image.
Interim compensating controls	Isolate the host on a restricted VLAN with no inbound internet exposure; deploy EDR and application whitelisting; keep any available cumulative updates/ESU current until migration.
Configuration hardening (fixable now)	Disable weak SSL/TLS cipher suites to close SWEET32 (42873); disable the built-in Guest account and remove it from groups (10907); apply the current .NET Framework rollup (314930).

This is a breakdown of every single **CRITICAL** vulnerability found in the 5562 ORLws1-[redacted]

PLUGIN ID	SEVERITY	CVSS	VULNERABILITY NAME
326867	**Critical**	9.9	KB5099539: Windows 10 version 21H2/ Windows 10 Version 22H2 Security Update (July 2026)

This is a breakdown of every single **HIGH** vulnerability found in the 5562 [redacted]

PLUGIN ID	SEVERITY	CVSS	VULNERABILITY NAME
274787	High	8.8	KB5068781: Windows 10 version 21H2/ Windows 10 Version 22H2 Security Update (November 2025)
166555	High	8.8	WinVerify Trust Signature Validation CVE-2013-3900 Mitigation (EnableCertPaddingCheck)

5563 [redacted]

END OF LIFE — Windows Server 2008 R2 reached end of support on January 14, 2020 (paid ESU ended January 2023). Confirmed by plugins 192782 (Server 2008 SEOL), 108797 (Unsupported Windows OS), and 22024 (unsupported Internet Explorer). No supported patch exists for its findings, which include wormable RCEs — SIGRed (CVE-2020-1350), BlueKeep (CVE-2019-0708), and EternalBlue (MS17-010).

Affected Component / Finding	Remediation
Operating system (primary remediation)	Migrate all roles (DNS, file, application services) to a supported Windows Server (2022 or 2025) with valid licensing, then decommission the 2008 R2 host. Rebuild rather than in-place upgrade given the age of the platform.
Interim compensating controls	Air-gap or tightly segment the host with zero internet access; block SMBv1 and RDP at the perimeter (BlueKeep/EternalBlue); require MFA and jump-host access; deploy EDR and stream logs to the SIEM.
Legacy application data	Remove or disable unsupported Internet Explorer and other legacy clients; migrate any application data to the replacement server before decommissioning.

This is a breakdown of every single **CRITICAL** vulnerability found in the 5562 ORLws1-[redacted]

PLUGIN ID	SEVERITY	CVSS	VULNERABILITY NAME
146342	Critical	10.0	KB4601363: Windows 7 and Windows Server 2008 R2 February 2021 Security Update
87893	Critical	10.0	MS KB3118753: Update for ActiveX Kill Bits
138554	Critical	10.0	Microsoft DNS Server Remote Code Execution (SIGRed)
22024	Critical	10.0	Microsoft Internet Explorer Unsupported Version Detection
192782	Critical	10.0	Microsoft Windows Server 2008 SEOL
108797	Critical	10.0	Unsupported Windows OS (remote)

5564 [redacted]

END OF LIFE — Windows 7 reached end of support on January 14, 2020 (paid ESU ended January 2023). Confirmed by plugins 192823 (Windows 7 SEOL), 108797 (Unsupported Windows OS), and 40362/213897 (unsupported Mozilla Firefox). Findings include BlueKeep (CVE-2019-0708) and EternalBlue (MS17-010).

Affected Component / Finding	Remediation
Operating system (primary remediation)	Migrate the workstation to Windows 10/11 (supported) with valid licensing or replace the hardware; then decommission the Windows 7 image.
Interim compensating controls	Isolate on a restricted VLAN with no internet access; disable SMBv1 and block RDP (BlueKeep); deploy EDR and application whitelisting.
Legacy software / hardening	Remove end-of-life Mozilla Firefox and the FileZilla FTP server (17593); disable the Guest account (10907); fix the unquoted service path (63155) and disable SWEET32 cipher suites (42873).

This is a breakdown of every single **CRITICAL** vulnerability found in the 5562 ORLws1-[redacted]

PLUGIN ID	SEVERITY	CVSS	VULNERABILITY NAME
146342	Critical	10.0	KB4601363: Windows 7 and Windows Server 2008 R2 February 2021 Security Update
87893	Critical	10.0	MS KB3118753: Update for ActiveX Kill Bits
22024	Critical	10.0	Microsoft Internet Explorer Unsupported Version Detection
192823	Critical	10.0	Microsoft Windows 7 SEOL
233423	Critical	10.0	Mozilla Firefox < 136.0.4
283709	Critical	10.0	Mozilla Firefox < 147.0
299865	Critical	10.0	Mozilla Firefox < 148.0

TICKET #104 — OPNsense Firewall (ORL) Combined CRITICAL Security Vulnerabilities (Update) - Credential Scan

Severity	CRITICAL	**Status**	CLOSED
Target IP	[redacted]	**Owner**	Abner D. Martinez Albizu
Date Created	2026-07-10 00:00:00	**Date Closed**	July 18th 2026
Time to Resolve	4h 0m	**Ticket ID**	104

Remediation Steps / Next Steps

Step 1 — Access
Logged into the Proxmox Virtual Environment web portal [redacted] using enterprise single sign-on credentials to access the laboratory cluster. Additionally, turn on the OPNsense firewall console via the Proxmox Virtual Environment (VM 5555) to provide connectivity to the network VM's

Step 2 — Snapshot
Created a baseline configuration snapshot before performing major updates to protect system state.

Step 3 — Console Upgrade
Once inside the VM select option 12 (Update from console) from the main menu to initiate the upgrade loop. (YOU MAY HAVE TO DO THIS STEP MULTIPLE TIMES)

Step 4 — Final Branch Target
Successfully advanced the core operating system kernel and base configuration to OPNsense 26.7. Additionally, Opened the root shell prompt and ran 'pkg update && pkg upgrade' to verify zero lingering packages remained.

Step 5 — Power Cycle
Executed a clean system reboot (Option 6) to flush legacy running services out of memory and initialize updated binaries.

Step 6 — Verification Scan
Turn on the kali VM, Go to Nessus, and executed a fresh Nessus credentialed scan to verify the resolution of Vulnerabilities

Step 7 —

Step 8 —

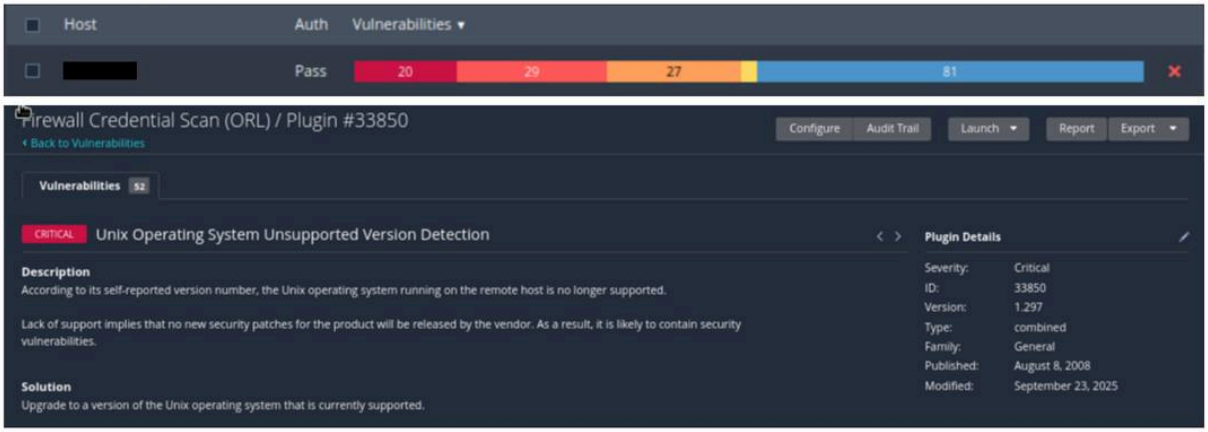
Fix / Resolution Report

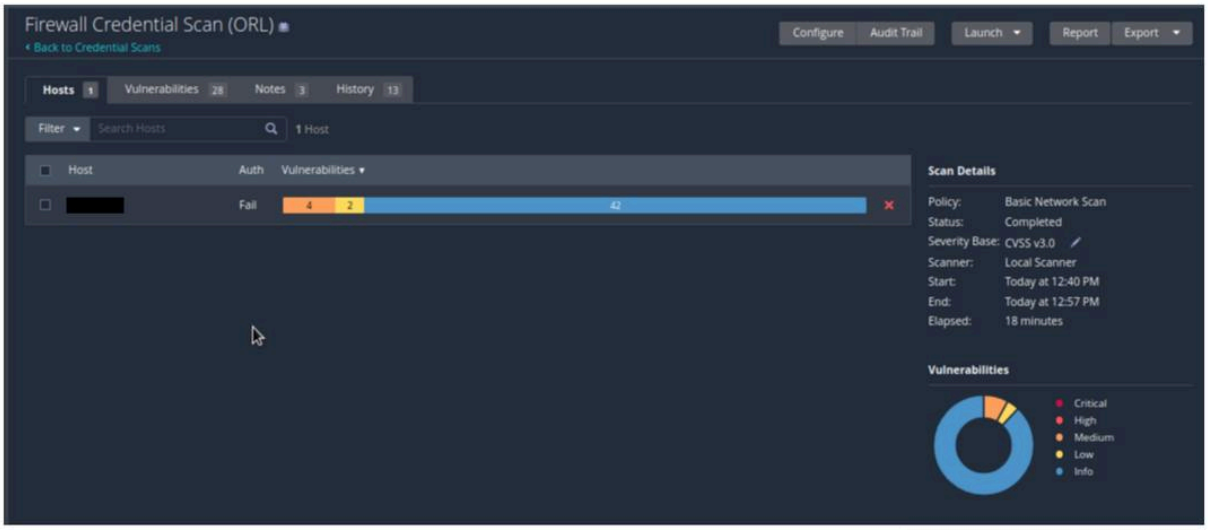
Fix Applied: Completed sequential major version upgrades of OPNsense OS and core packages to version 26.7.
Date Fixed: July 18th 2026
Fixed By: Abner D. Martinez
Status: CLOSED

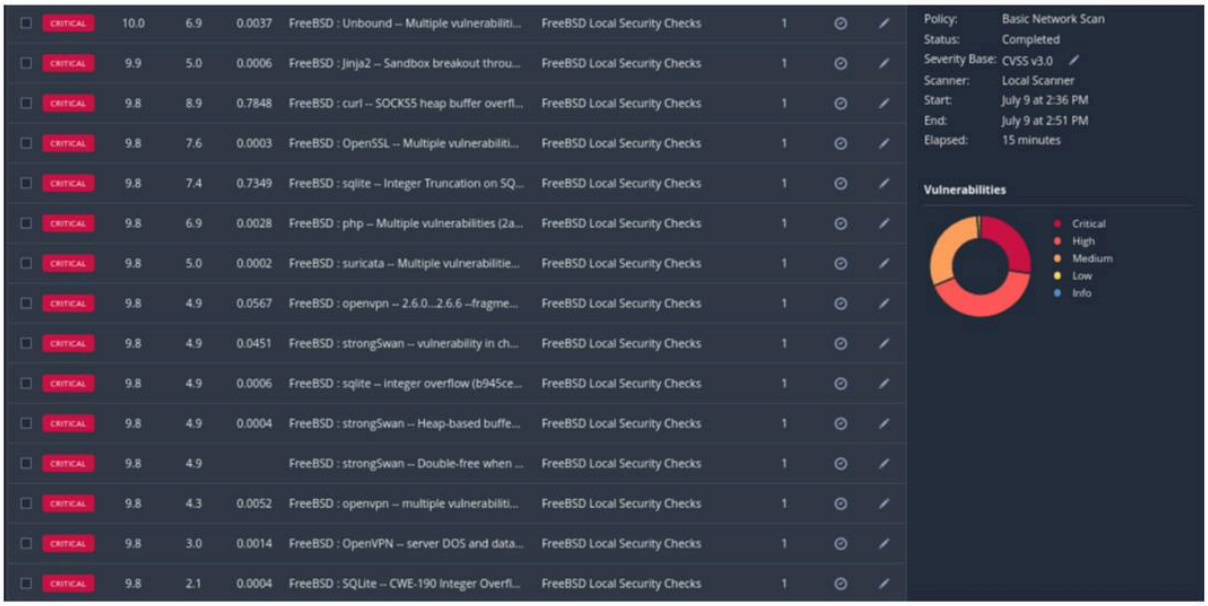
Additional Notes / Observations

The firewall system is completely up to date. We will create a new ticket for the SSH service to track and remediate the single remaining OpenSSH (< 10.4) Critical vulnerability. This single leftover finding is an upstream vendor limitation; OPNsense 26.7 is running the newest stable production package available in the FreeBSD repositories. The separate ticket will manage the deployment of the OpenSSH 10.4 patch once it is officially packaged and published to the stable distribution tree.

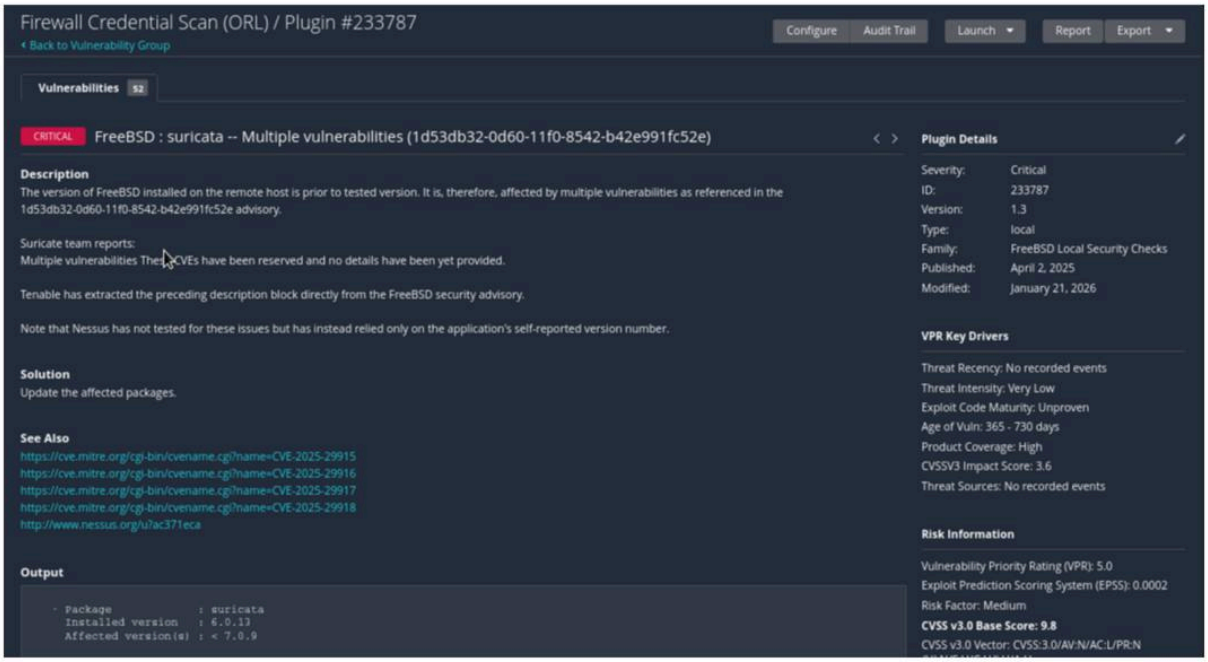
Screenshot Evidence (6)




Firewall Credential Scan (ORL)
Back to Credential Scans
Configure
Audit Trail
Launch
Report
Export
Hosts 1
Vulnerabilities 28
Notes 3
History 13
Filter
Search Hosts
1 Host
Host
Auth
Vulnerabilities
Fail
4
2
42
Scan Details
Policy: Basic Network Scan
Status: Completed
Severity Base: CVSS v3.0
Scanner: Local Scanner
Start: Today at 12:40 PM
End: Today at 12:57 PM
Elapsed: 18 minutes
Vulnerabilities
Critical
High
Medium
Low
Info


CRITICAL 10.0 6.9 0.0037 FreeBSD : Unbound -- Multiple vulnerabiliti... FreeBSD Local Security Checks 1
CRITICAL 9.9 5.0 0.0006 FreeBSD : Jinja2 -- Sandbox breakout throu... FreeBSD Local Security Checks 1
CRITICAL 9.8 8.9 0.7848 FreeBSD : curl -- SOCKS5 heap buffer overfl... FreeBSD Local Security Checks 1
CRITICAL 9.8 7.6 0.0003 FreeBSD : OpenSSL -- Multiple vulnerabiliti... FreeBSD Local Security Checks 1
CRITICAL 9.8 7.4 0.7349 FreeBSD : sqlite -- Integer Truncation on SQ... FreeBSD Local Security Checks 1
CRITICAL 9.8 6.9 0.0028 FreeBSD : php -- Multiple vulnerabilities (2a... FreeBSD Local Security Checks 1
CRITICAL 9.8 5.0 0.0002 FreeBSD : suricata -- Multiple vulnerabilitie... FreeBSD Local Security Checks 1
CRITICAL 9.8 4.9 0.0567 FreeBSD : openvpn -- 2.6.0...2.6.6 --fragme... FreeBSD Local Security Checks 1
CRITICAL 9.8 4.9 0.0451 FreeBSD : strongSwan -- vulnerability in ch... FreeBSD Local Security Checks 1
CRITICAL 9.8 4.9 0.0006 FreeBSD : sqlite -- integer overflow (b945ce... FreeBSD Local Security Checks 1
CRITICAL 9.8 4.9 0.0004 FreeBSD : strongSwan -- Heap-based buffe... FreeBSD Local Security Checks 1
CRITICAL 9.8 4.9 FreeBSD : strongSwan -- Double-free when ... FreeBSD Local Security Checks 1
CRITICAL 9.8 4.3 0.0052 FreeBSD : openvpn -- multiple vulnerabiliti... FreeBSD Local Security Checks 1
CRITICAL 9.8 3.0 0.0014 FreeBSD : OpenVPN -- server DOS and data... FreeBSD Local Security Checks 1
CRITICAL 9.8 2.1 0.0004 FreeBSD : SQLite -- CWE-190 Integer Overfl... FreeBSD Local Security Checks 1
Policy: Basic Network Scan
Status: Completed
Severity Base: CVSS v3.0
Scanner: Local Scanner
Start: July 9 at 2:36 PM
End: July 9 at 2:51 PM
Elapsed: 15 minutes
Vulnerabilities
Critical
High
Medium
Low
Info


CRITICAL 9.4 4.5 0.3786 FreeBSD : php -- Multiple vulnerabilities (6d... FreeBSD Local Security Checks 1
CRITICAL 9.1 7.7 0.0012 FreeBSD : OpenSSL -- Multiple vulnerabiliti... FreeBSD Local Security Checks 1
CRITICAL 9.1 4.3 0.0018 FreeBSD : openvpn -- two security fixes (14... FreeBSD Local Security Checks 1
CRITICAL 9.1 3.0 0.0002 FreeBSD : unbound -- Cache poisoning via t... FreeBSD Local Security Checks 1


Firewall Credential Scan (ORL) / Plugin #233787
Back to Vulnerability Group
Configure
Audit Trail
Launch
Report
Export
Vulnerabilities 52
CRITICAL
FreeBSD : suricata -- Multiple vulnerabilities (1d53db32-0d60-11f0-8542-b42e991fc52e)
Description
The version of FreeBSD installed on the remote host is prior to tested version. It is, therefore, affected by multiple vulnerabilities as referenced in the 1d53db32-0d60-11f0-8542-b42e991fc52e advisory.
Suricate team reports:
Multiple vulnerabilities. These CVEs have been reserved and no details have been yet provided.
Tenable has extracted the preceding description block directly from the FreeBSD security advisory.
Note that Nessus has not tested for these issues but has instead relied only on the application's self-reported version number.
Solution
Update the affected packages.
See Also
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-29915
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-29916
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-29917
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-29918
http://www.nessus.org/u?ac371eca
Output
- Package : suricata
Installed version : 6.0.13
Affected version(s) : < 7.0.9
Plugin Details
Severity: Critical
ID: 233787
Version: 1.3
Type: local
Family: FreeBSD Local Security Checks
Published: April 2, 2025
Modified: January 21, 2026
VPR Key Drivers
Threat Recency: No recorded events
Threat Intensity: Very Low
Exploit Code Maturity: Unproven
Age of Vuln: 365 - 730 days
Product Coverage: High
CVSSV3 Impact Score: 3.6
Threat Sources: No recorded events
Risk Information
Vulnerability Priority Rating (VPR): 5.0
Exploit Prediction Scoring System (EPSS): 0.0002
Risk Factor: Medium
CVSS v3.0 Base Score: 9.8
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N

TICKET #107 — ORL Server Combined CRITICAL Security Vulnerabilities (Update) - Credential Scan			
Severity	**CRITICAL**	**Status**	**CLOSED**
Target IP	[redacted]	**Owner**	Abner D. Martinez-Albizu
Date Created	July 12th 2026	**Date Closed**	Closed
Time to Resolve	4h 0m	**Ticket ID**	107

Remediation Steps / Next Steps

Step 1 — Access

Logged into the Proxmox Virtual Environment web portal [redacted] using enterprise single sign-on credentials to access the laboratory cluster. Additionally, turn on the OPNsense firewall console via the Proxmox Virtual Environment (VM 5555) to provide connectivity to the network VM's

Step 2 — Snapshot

Created a baseline configuration snapshot before performing major updates to protect system state.

Step 4 — Turn-on Server

Selected the target Windows Server virtual machine 5556 [redacted] from the Proxmox pool view tree and brought the host operational.

Step 5 — Create a snapshot

Navigated to the native Snapshots menu interface for VM 5556 and generated a clean, pre-remediation backup snapshot to preserve baseline operational parameters before applying system modifications.

Step 5 — Update Windows & Restart

Launched the noVNC Console interface to log into the Windows Server desktop environment. Once at the desktop, Go click on the Windows Key > Settings > >Update & Security> Click on "Check for updates > Download > Install. Once these updates are installed the system itself will reboot.

Step 6 — Verification Scan

Turn on the kali VM, Go to Nessus, and executed a fresh Nessus credentialed scan to verify the resolution of Vulnerabilities

Fix / Resolution Report

Fix Applied: Verified environment baseline connectivity, captured a secure pre-patch snapshot rollback point within Proxmox, and forced an upstream definition sync via the graphical Windows Update utility to guarantee complete operating system patching alignment.

Date Fixed: July 17th 2026

Fixed By: Abner D. Martinez-Albizu

Status: CLOSED

Additional Notes / Observations

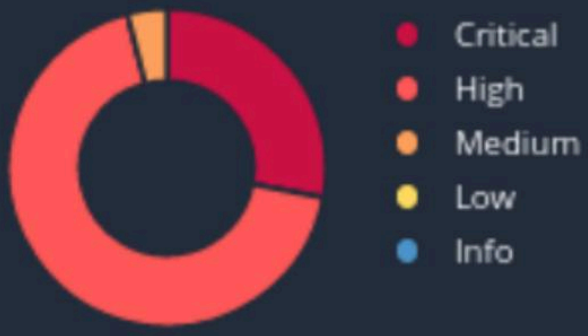
The local graphical Windows Update dashboard explicitly logs an active, pristine baseline status confirming: "You're up to date. Last checked: Today, 2:12 PM". The manual verification scan completed successfully with zero pending package dependencies or blocking software definition errors.

Screenshot Evidence (7)

Scan Details

Policy:	Basic Network Scan
Status:	Completed
Severity Base:	CVSS v3.0
Scanner:	Local Scanner
Start:	July 9 at 3:02 PM
End:	July 9 at 3:21 PM
Elapsed:	19 minutes

Vulnerabilities

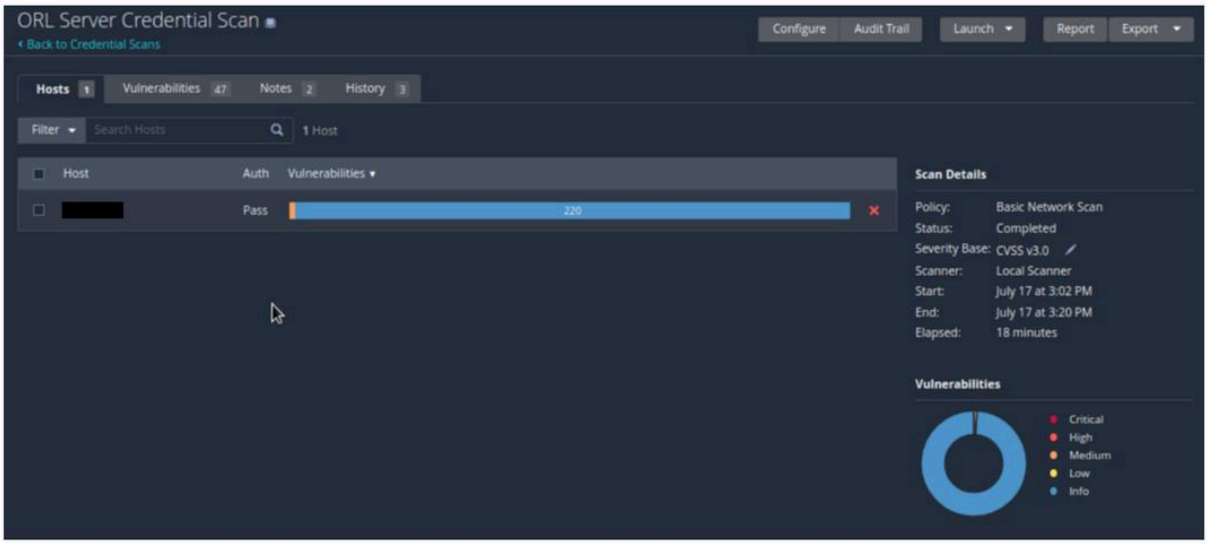


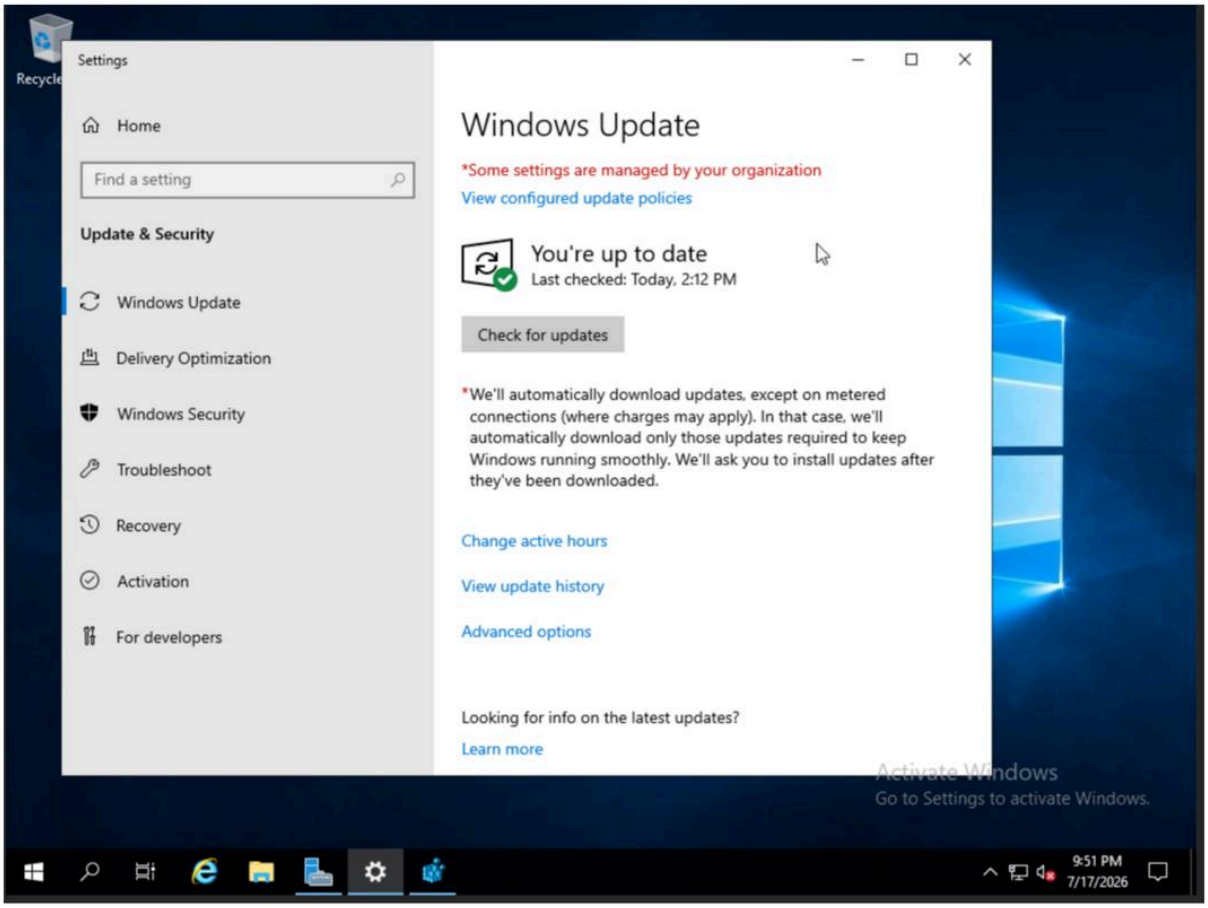
172.16.1.3	Pass	15	35	228

CRITICAL	9.9	9.5	0.0824	KB5066586: Windows 10 version 1809 / Wi...	Windows : Microsoft Bulletins	1			
CRITICAL	9.8	9.6	0.8182	KB5046615: Windows 10 version 1809 / Wi...	Windows : Microsoft Bulletins	1			
CRITICAL	9.8	9.5	0.8435	KB5040430: Windows 10 version 1809 / Wi...	Windows : Microsoft Bulletins	1			
CRITICAL	9.8	9.5	0.7056	KB5041578: Windows 10 version 1809 / Wi...	Windows : Microsoft Bulletins	1			
CRITICAL	9.8	8.9	0.5188	KB5043050: Windows 10 version 1809 / Wi...	Windows : Microsoft Bulletins	1			
CRITICAL	9.8	7.9	0.3607	KB5063877: Windows 10 version 1809 / Wi...	Windows : Microsoft Bulletins	1			
CRITICAL	9.0	9.5	0.6095	KB5044277: Windows 10 version 1809 / Wi...	Windows : Microsoft Bulletins	1			

CRITICAL	9.8	9.7	0.9908	KB5029247: Windows 10 version 1809 / Wi...	Windows : Microsoft Bulletins	1		
CRITICAL	9.8	9.7	0.882	KB5032196: Windows 10 version 1809 / Wi...	Windows : Microsoft Bulletins	1		
CRITICAL	9.8	9.6	0.3231	KB5028168: Windows 10 version 1809 / Wi...	Windows : Microsoft Bulletins	1		
CRITICAL	9.8	9.2	0.1855	KB5027222: Windows 10 version 1809 / Wi...	Windows : Microsoft Bulletins	1		
CRITICAL	9.8	6.9	1.0	KB5031361: Windows 10 version 1809 / Wi...	Windows : Microsoft Bulletins	1		

CRITICAL	9.8	5.7	0.9862	Security Updates for Microsoft .NET Frame...	Windows : Microsoft Bulletins	1		
CRITICAL	9.8	4.9	0.0864	Security Updates for Microsoft .NET Frame...	Windows : Microsoft Bulletins	1		
CRITICAL	9.8	3.0	0.0003	Security Updates for Microsoft .NET Frame...	Windows : Microsoft Bulletins	1		




Settings
Home
Find a setting
Update & Security
Windows Update
Delivery Optimization
Windows Security
Troubleshoot
Recovery
Activation
For developers
Windows Update
*Some settings are managed by your organization
View configured update policies
You're up to date
Last checked: Today, 2:12 PM
Check for updates
*We'll automatically download updates, except on metered connections (where charges may apply). In that case, we'll automatically download only those updates required to keep Windows running smoothly. We'll ask you to install updates after they've been downloaded.
Change active hours
View update history
Advanced options
Looking for info on the latest updates?
Learn more
Activate Windows
Go to Settings to activate Windows.
9:51 PM
7/17/2026

Conclusion

- **Task 1:** Unauthorized account hacker1 identified and validated in /etc/passwd and /etc/shadow; dormant backdoor, recommended for removal.
- **Task 2:** Most vulnerable directory identified as /tmp (1777, world-writable + sticky bit); hidden file to be captured on a fresh VM copy.
- **Task 3:** History reflects an authorized Nessus scan plus a permission-loosening chmod; main concerns are plaintext exposure of privileged activity and over-permissive WordPress files.
- **Task 4:** SFO-SERVER1 was isolated by a disabled firewall interface; re-enabling it restored connectivity. The credentialed scan revealed an End-of-Life Windows Server 2008 R2 with 70+ criticals (SIGRed, BlueKeep, EternalBlue) — remediated only by migrating off the unsupported OS.